GUIDE · ARCHITECTURE

CRM Sync — Why This Architecture Is Safer

Why this architecture is safer: **Xano** is the source of truth, **Cloudflare** is the resilient runtime, and no single platform is ever both your database and your runtime dependency.

For: **Business leaders, compliance officers, and operations teams evaluating CRM Sync**

Date: **2026-05-18**

THE PROBLEM

Most e-commerce apps are built as a single application that does everything: renders the website, processes customer data, stores passwords, connects to marketing platforms, and manages payments. If any part of that application has a security flaw, an attacker can access everything — your customer database, your API keys, your consent records, all of it.

This is not theoretical. In 2024-2025, breaches at SolarWinds, MOVEit, Polyfill.io, and others all followed the same pattern: one compromised component gave attackers access to the entire system.

For a product that handles customer personal data, consent preferences, and payment entitlements across Shopify, Webflow, Google Analytics, Adobe, and multiple marketing platforms — that risk is unacceptable.

HOW CRM SYNC IS DIFFERENT

CRM Sync separates responsibilities across independent systems. No single system can access everything:

LAYER	WHAT IT DOES	WHAT IT CANNOT DO
Webflow Extension (the interface your team sees)	Display settings, show sync status, trigger actions	Cannot access customer data, credentials, or the database
Cloudflare Worker (the processing engine)	Route requests, verify identity, enforce consent rules	Cannot access the filesystem, run programs, or query the database directly
Xano (the database)	Store customer records, consent history, sync logs	Cannot be accessed except through authenticated API calls
Shopify / Webflow / GA4 / Adobe (partner platforms)	Receive data only when consent is verified	Cannot pull data — they receive it from the Worker only when conditions are met

The key difference: if one layer is compromised, the attacker only gets access to what that layer can do — not the entire system.

Comparison: Traditional App vs. CRM Sync

WHAT HAPPENS IF...	TRADITIONAL APP (ONE SYSTEM)	CRM SYNC (SEPARATED SYSTEMS)
A password or key is leaked	Attacker gets full database access	Attacker gets access to one tenant's API calls — not raw database access
A software dependency has a vulnerability	Attacker can read files, run commands, steal data	No third-party code runs in production — nothing to exploit
An admin page has a bug	Attacker can read all customer data across all clients	Attacker can only access data for one specific store
Someone forgets to add a security check	Attacker accesses everything behind that check	Consent enforcement is built into the system — it can't be turned off with a setting

For Compliance Officers

Three questions you can answer in under 5 minutes:

1. **"Where are credentials stored?"** — In Cloudflare's encrypted key-value store. Never in code, never in files, never visible in API responses.
2. **"Where does customer data go?"** — Only to platforms that are enabled in the configuration AND where the customer has given consent. Every transfer is logged.
3. **"What happens if a partner is compromised?"** — Flip one toggle to disable that partner. Their credentials are never read again. No code change needed. Takes less than 30 seconds.

For Operations Teams

CONCERN	HOW CRM SYNC HANDLES IT
Adding a new marketing platform	Add credentials to config, enable it — the security model, consent checks, and audit logging are inherited automatically
Removing a partner	Set one toggle to "off" — done in seconds, no developer needed
Rotating a compromised credential	Update the credential in config — same process as any other config change, logged and reversible
Auditing who changed what	Every configuration change is authenticated and can be logged with before/after comparison
Scaling to more stores	Each store has its own isolated configuration with region-based grouping (US/CA/DE/FR/UK) and per-tenant admin keys — one store's issues cannot affect another

For Risk Assessment

RISK FACTOR	TRADITIONAL APPROACH	CRM SYNC APPROACH
Third-party software dependencies	200-800 packages, each a potential vulnerability	Zero third-party packages in production
Credential storage	Scattered across environment files, CI pipelines, config files	Single encrypted store per tenant
Blast radius of a breach	All tenants, all data, all systems	One tenant, one system, limited access
SOC 2 audit surface	Multiple systems, SDKs, credential stores	Cloudflare (SOC 2 Type II) + Xano (managed platform)
Partner onboarding/offboarding	Find all credential references, update across environments	One config field per partner

WHEN THIS ARCHITECTURE MATTERS MOST

This approach is built for organizations that:

- Handle customer personal data across multiple marketing and analytics platforms
- Need to prove consent compliance under GDPR, CCPA, or similar regulations
- Operate as multi-tenant SaaS (serving multiple stores or brands)
- Want to add or remove partner integrations without security reviews each time
- Need to answer auditor questions quickly and definitively

For a simple internal tool or marketing website, a traditional all-in-one framework is faster to build and perfectly adequate. CRM Sync's architecture is purpose-built for the scenario where a security incident affects real customers across real systems — and the cost of that incident is measured in regulatory fines, lost trust, and partner liability.

Technical reference: FEATURE-SPEC-UA-MIGRATION.md
